Decision Analytics Journal 9 (2023) 100328

Contents lists available at ScienceDirect

Decision Analytics Journal

journal homepage: www.elsevier.com/locate/dajour

A cybersecurity risk quantification and classification framework for informed risk mitigation decisions

Amir Zadeh [a,*], Brandon Lavine [a], Hamed Zolbanin [b], Donald Hopkins [a]

[a] Department of Information Systems and Supply Chain Management, Raj Soin College of Business, Wright State University, Dayton, OH 45435, USA
[b] Department of MIS, OSC and Business Analytics, College of Business, University of Dayton, Dayton, OH 45469, USA

ARTICLE INFO

Keywords:
Cybersecurity
Information security
Data breach severity classification
Content analysis
Risk mitigation
Likelihood impact matrix analysis

ABSTRACT

Data breaches have been causing havoc for many years and continue to rise, demanding a more comprehensive framework to assess their severity. This study proposes a cybersecurity risk quantification and classification framework, addressing a significant research gap in breach severity evaluation. The study has two main objectives: to present a structured model for precise breach severity assessment, and to apply this model to real-world data breaches for practical insights. To achieve these objectives, we utilize a content analysis methodology to gauge severity of data breaches. This is followed by a robust likelihood impact matrix analysis, serving as a decision analytics tool, to effectively quantify potential risks. The integration of these approaches yields a more comprehensive and nuanced evaluation for assessing data breach severity. The proposed framework is then applied to data breaches gathered from Standard & Poor's (S&P 500) organizations, revealing hacking and loss/theft of portable media as the breach types with the highest impact and probability. Drawing from these insights, our study suggests effective strategies to mitigate data breach risks for organizations. The implications of our research findings offer valuable contributions to both academic research and practical cybersecurity risk management.

1. Introduction

In recent times, the financial repercussions of data breaches have reached staggering proportions, with the average breach cost escalating to $4.35 million according to a report by IBM Security[1] [1]. The average cost of a breach for an organization amounts to $3.86 million, as indicated by Ponemon [2], with data breaches being particularly costly in the United States. The United States has witnessed a significant surge in annual data breach counts, amplifying the potential consequences for both organizations and individuals [3]. These breaches not only lead to substantial financial losses but also trigger legal actions and fines [4].

Despite the imperative to safeguard data, breaches continue to pose significant challenges, especially for small businesses that may face bankruptcy within few years of an incident [5]. Organizations are compelled to interact with stakeholders, emphasizing confidentiality, integrity, and availability of information systems [6]. Cybersecurity breaches can adversely impact market value, stock price, and returns [7], necessitating immediate response. However, quantifying breach severity and its diverse impact remains a complex task [8].

Most conventional risk assessment methods utilized in information security rely on experts' expertise and subjective understanding. They primarily center on basic scales or measurements to evaluate the potential adverse consequences of data breach incidents. One such widely adopted approach involves the use of basic three-level ordinal scales, which categorize breaches as "low", "medium", or "high" in severity. Another class of methods rely on probabilistic risk analysis to quantify breach impact using a ratio scale, often expressed in monetary terms. Whether these assessments are conveyed as ordinal or ratio values, the process of estimating impact plays a pivotal role in effective risk management [9]. Existing research often falls short of adopting a comprehensive perspective that simultaneously considers both the impact (i.e., severity) and likelihood (i.e. frequency) of breaches. This limitation leads to insufficient evaluations of breach severity, leaving organizations ill-equipped to adequately address their potential consequences. This research gap has been acknowledged in the extant literature [10], with an increasing recognition that the extent of severity notably influences the strategies that firms adopt in response to such incidents [11].

* Corresponding author.
E-mail addresses: amir.zadeh@wright.edu (A. Zadeh), lavine.4@wright.edu (B. Lavine), hmzolbanin@udayton.edu (H. Zolbanin), donald.hopkins@wright.edu (D. Hopkins).
URLs: https://people.wright.edu/amir.zadeh (A. Zadeh), https://udayton.edu/directory/business/mis_osc_and_business_analytics/zolbanin-hamed.php (H. Zolbanin), https://people.wright.edu/donald.hopkins (D. Hopkins).

[1] https://www.statista.com/statistics/273550/data-breaches-recorded-in-the-united-states-by-number-of-breaches-and-records-exposed/

https://doi.org/10.1016/j.dajour.2023.100328
Received 5 June 2023; Received in revised form 7 August 2023; Accepted 19 September 2023
Available online 21 September 2023
2772-6622/© 2023 The Author(s). Published by Elsevier Inc. This is an open access article under the CC BY license (http://creativecommons.org/licenses/by/4.0/).

The purpose of this study is to bridge the gap by presenting a framework for a more comprehensive assessment of data breaches. This is achieved through the implementation of a structured model, designed to systematically quantify both the likelihood and impact of data breaches. We present a cybersecurity risk quantification and classification framework, which effectively addresses a noteworthy gap in the evaluation of breach severity. More specifically, our study encompasses two primary objectives: firstly, to present a structured model to enable precise assessment of breach severity; and secondly, to apply the practical application of this model to real-world data breaches, yielding valuable insights. To achieve these objectives, our methodology involves employing content analysis to gauge data breach severity, bolstered by a robust analysis utilizing a likelihood-impact matrix as a strategic decision analytics tool for quantifying potential breach risks. We amalgamate descriptive, diagnostic, and predictive modeling techniques to evaluate breach severity and organizational responses. Through an analysis of historical breach data and the development of a comprehensive assessment framework, our research contributes to identifying organizational risks and opportunities by leveraging data patterns. Our findings demonstrate that this integration yields a comprehensive and nuanced evaluation, significantly enhancing our capacity to assess breach severity. We illustrate the efficacy of our proposed framework using a dataset comprising breaches from Standard & Poor's (S&P 500) organizations. By quantifying breach severity, organizations can prioritize their cybersecurity efforts, allocate resources effectively, and implement security measures aligned with the risk level posed by different breach types. This approach empowers organizations to address the most severe breaches first, mitigating their impact and enhancing their ability to safeguard sensitive data.

Therefore, this study makes four primary contributions to the cybersecurity field. Firstly, we propose an assessment framework to study data breaches, which adds to the existing literature on cybersecurity. Secondly, we provide a detailed analysis of S&P 500 data breaches over the past fifteen years, examining their likelihood and impact, and offering valuable insights into the trends and patterns of these incidents. Thirdly, we contribute to the decision analytics literature by demonstrating how decision analytics methods such as likelihood-impact analysis can help organization assess the potential risks associated with different data breach scenarios. By quantifying the likelihood of a breach and its potential impact, decision-makers can prioritize their actions and resources based on the level of risk posed by each scenario. Lastly, we provide an interactive visualization dashboard that enables us to explore and categorize data breaches based on their severity.

The next section presents a review of relevant literature that informed this study. The subsequent section details the research method used to identify the characteristics of data breaches. Next, we present the analysis and discussion sections, which outline the characterization of cybersecurity data breaches and the development of potential strategies to mitigate them. The paper will conclude with a summary of results and suggestions for future research.

2. Prior literature

Previous studies on cybersecurity have examined a range of issues related to both organizational and operational aspects. This includes identifying potential threats or vulnerabilities [4,12]; exploring mechanisms behind cybersecurity breaches and attacks [13,14]; developing frameworks or models for assessing, predicting, and mitigating cybersecurity attacks [15–20]; investigating the social, economic, and financial impacts of data breaches [21–23]; and analyzing the routines, structures, and capabilities necessary for effective cybersecurity responses by organizations [24,25]. For instance, Gordon, Loeb, Sohail, Tseng and Zhou [26] discussed the importance of leadership processes, organizational structures, and capital allocations in managing cybersecurity through the installation of Chief Information Security Officer (CISO) positions within organizations. Jeyaraj and Zadeh [27] investigated the roles of institutional pressures by examining how mimetic pressures, normative pressures, and coercive pressures influence organizational cybersecurity responses over time. Tavana, Nasr, Ahmadabadi, Amiri and Mina [20] presented a practical approach employing multi-criteria decision-making to assess and choose appropriate blockchain and Internet of Things platforms for supply chain networks. This method considers criteria interdependencies and experts' preferences, showcasing the efficacy of these technologies in preventing data breaches and cyber-attacks within supply chain networks.

The rapid expansion of cyberspace has led to an ongoing and pressing challenge in devising effective strategies to combat the escalating threat of cybersecurity breaches. These breaches pose a significant risk to the security and confidentiality of personally identifiable information (PII), encompassing a wide range of sensitive data such as user accounts, names, addresses, social security numbers, financial records, passwords, and medical histories. The potential malicious use of this information by cybercriminals underscores the critical importance of safeguarding PII from unauthorized access and exploitation [28,29]. Within this landscape, the deployment of advanced analytics tools offers a promising avenue for addressing the multifaceted nature of cybersecurity challenges. Descriptive, diagnostics and predictive analytics, in particular, emerge as viable solutions that leverage data-driven insights to enhance cyber defense strategies. Predictive diagnostics entail the proactive identification of potential vulnerabilities and threats by analyzing historical data patterns and trends [30,31]. This has prompted a demand for further research into the potential of big data driven analytical models within the realm of cybersecurity, given their capacity to facilitate informed decisions, anticipate and proactively mitigate potential breaches, thereby fortifying overall security measures [32].

Data breaches can be due to unintended disclosure (DISC), hacking or malware (HACK), fraud involvement around account information (CARD), insiders accessing sensitive information (INSD), loss or stolen assets or records (PHYS), loss of portable media (PORT), and loss of digital equipment like a desktop computer (STAT) [6]. Unintended disclosure (DISC) refers to the accidental disclosure of sensitive information to unintended parties, with the impact on businesses depending on the nature of the information disclosed. Hacking or malware (HACK) involves the use of unauthorized access to gain entry to a system or network, with the consequences varying based on the level of access gained and the sensitivity of the information obtained [33]. Fraud involving account information (CARD) is characterized by the unauthorized access of sensitive account information, such as credit card or bank account details, and the use of this information for fraudulent activities. The extent of the breach depends on the amount of information accessed and the extent of the fraud. Insiders accessing sensitive information (INSD) involves the unauthorized access of sensitive information by authorized personnel, such as employees, which can have significant repercussions depending on the level of access and the sensitivity of the information obtained. Loss or theft of assets or records (PHYS), portable media (PORT), and digital equipment (STAT) occur when physical assets or records, such as laptops, files, or paper records; portable storage devices, such as USB drives; or a desktop computer are lost or stolen [6,34,35]. The impact of these types of breaches depends on the sensitivity of the information stored on the assets, records, media, or devices. The breaches are also categorized by the type of industry and include Business, Financial and Insurance services (BSF), Business, Retail/Merchant entities (BSR), Educational Institutions (EDU), Government and Military (GOV), Healthcare and Medical providers (MED), Nonprofit (NGO), and other businesses category (BSO) [6].

Mandatory breach reporting laws have been enacted in all 50 states in the United States, as well as in other countries such as Australia, the UK, and the EU. The introduction of mandatory reporting requirements has made breach incidents more visible to the public [36]. Chen, Henry and Jiang [37] investigated managers' decisions regarding the disclosure of risk factors for firms and concluded that these risk

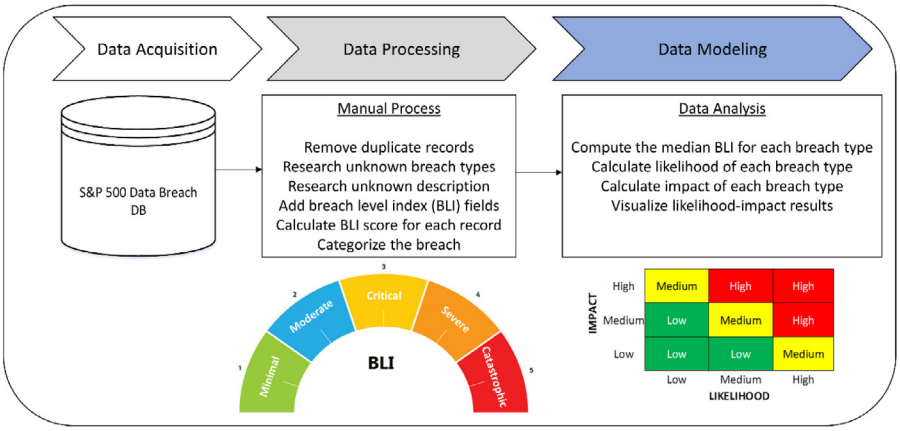

Fig. 1. Research framework.

factor disclosures provide valuable information. In response to a data breach, decision-makers must take appropriate steps, including contacting a legal expert before speaking to anyone else [38]. Additionally, there are minimum thresholds for the number of records that must be compromised to trigger a mandatory reporting requirement [39–41].

The severity of a breach is a multifaceted phenomenon influenced by a myriad of interconnected factors, each contributing to the overall impact and consequences of the breach [42]. These factors encompass a wide range of elements, including the nature and sensitivity of compromised data, the scope of individuals affected, the duration of the breach, the effectiveness of security measures in place, and the potential financial and reputational damages incurred [43]. Moreover, the context in which the breach occurs, such as the industry [44], regulatory environment [45], and geographic location [46], can further amplify or mitigate its severity. Additionally, the speed and effectiveness of incident response efforts [47], as well as the organization's ability to communicate and mitigate the breach's aftermath [48], play a crucial role. Recognizing the intricate interplay of these factors is essential for accurately assessing and comprehending the true severity of a breach. Failure to consider these nuances can lead to an inadequate understanding of the breach's implications, hindering effective response strategies and risk management measures. Therefore, a comprehensive and holistic approach that carefully examines these diverse factors is imperative to accurately gauge the severity of a breach and guide appropriate actions for mitigation and recovery.

The breach level index (BLI), developed by Stiennon [49], is a widely used metric for measuring the severity of a data breach. It measures the severity of a data breach based on four weighted variables (i.e., number of records, type of data, source of the breach, and whether or not the data has been used for nefarious purposes) and will help organizations better understand the impact of data breaches on their operations [50]. In this study, we utilize the BLI to assess the probability and severity of potential data breaches across diverse industries. By applying the BLI to analyze breach types and categories, decision-makers can gain insights into cyber threats, shaping effective risk mitigation strategies. Our approach not only identifies data breach likelihood and impact of but also enables organizations to proactively steer and alleviate cybersecurity risks.

3. Research methodology

Our research methodology consists of four major phases: data acquisition, data processing, data modeling, and data analysis [51]. The analytical methodology used in this study is depicted in Fig. 1, illustrating how we identified the characteristics of data breaches. Our framework consists of two components: risk quantification and risk classification. Our framework first leverages a breach index formula to characterize risks based on past breach incidents among S&P 500 organizations. After quantification, further assessment is performed to classify cyber risks in terms of likelihood and impact.

Data Acquisition

The database of data breaches maintained by the Privacy Rights Clearinghouse[2] was accessed to obtain data on cybersecurity breaches previously encountered by the top 500 organizations as listed in S&P 500 rankings [52]. The original dataset was the source of about 9,000 records from the state attorney general and the U.S. Department of Health and Human Services. Acquiring a list of breaches in the top S&P 500 companies dated back to 2005 and excluding all the companies that were not on the S&P 500 helped narrow down the data to a manageable size for in-depth content analysis.

Data preprocessing

Our dataset was classified by breach and institution type, number of records exposed, location, and some description of the situation surrounding each data breach. The breaches were organized by types (e.g., unintended disclosure, hacking or malware, payment card fraud, malicious insider, physical loss, portable device, stationary device, unknown). By reviewing the description of the incident, the breach type, and the number of compromised records in the breach, a large number of duplicate records and irrelevant data were removed. This gave us a true number of data breaches over the last 15 years. This manual process allowed for a better understanding of data breaches and how they resembled each other. Our final dataset included 469 data breaches between 2005 and 2019 from different industries. Accounting for duplicates, we found that almost 1.5 billion records were compromised within the S&P 500 throughout the years.

The manual process began with sorting by the company name. We started by cleaning similar company names; for example, Target Inc. and Target Company. This required research to see if the companies were indeed the same and that the date, type, and description of the breach were indeed a duplicate. This process was done for 30 records, and as a result, over 100 million records of breaches were removed due to redundancy. Also, additional research was done to make sure that companies were not bought out or the company name had not changed.

In addition, several breaches had an "unknown" type. Replacing the unknowns with a definite data breach type would make our results more accurate. This was a significant aspect of our manual data cleaning process, which required considerable time and thorough investigation. A detailed examination was conducted to ascertain the actual cause of each breach labeled as "unknown" in the original dataset. It is worth noting that automating this process proved challenging due to the absence of a standardized approach. For some breaches lacking a definitive cause, they were categorized as *unknown*. In instances

[2] https://privacyrights.org/data-breaches

Table 1
Descriptive statistics — (Means–SDs in parentheses).

Industry type	BSF	BSO	BSR	EDU	GOV	MED	NGO	Overall avg. (SD)
CARD	5.44 (1.29)		5.33 (0.00)					5.43 (1.19)
DISC	3.17 (2.59)	4.04 (3.11)	3.69 (3.74)	1.60 (2.77)	2.59 (3.66)	2.68 (2.25)		3.14 (2.74)
HACK	5.98 (2.38)	5.95 (1.73)	6.49 (2.68)	3.65 (0.00)		4.33 (1.83)	3.28 (0.00)	5.63 (2.27)
INSD	4.70 (1.83)	5.12 (1.09)	3.86 (1.23)			3.81 (1.63)		4.33 (1.58)
PHYS	3.91 (0.26)	3.70 (0.00)	3.98 (0.00)	3.28 (0.00)	2.60 (0.00)	3.90 (1.26)		3.82 (1.14)
PORT	4.52 (1.90)	4.96 (0.90)	4.45 (1.42)		4.30 (1.98)	4.71 (1.45)		4.66 (1.47)
STAT	6.07 (1.14)	5.75 (0.00)	2.72 (0.00)			5.82 (0.11)		5.37 (1.47)
UNKN	3.52 (0.00)	6.51 (2.08)						5.01 (1.40)
Overall Avg. (SD)	4.67 (2.17)	5.13 (2.01)	4.89 (2.61)	2.34 (2.21)	3.45 (1.93)	3.72 (1.93)	3.28 (0.00)	4.43 (2.23)

where breach descriptions did not provide sufficient information for classification, we conducted comprehensive research using additional sources to determine the true nature of the breach incident. To provide illustrative examples of our data cleaning and classification efforts, we have included three specific breach cases, along with the resources utilized for their type determination, in Appendix B.

Data Modeling

The BLI method, as formulated by Stiennon [49] served as the tool for assessing data breach severity. According to Stiennon [49], the severity of a breach depends on four weighted values: number of records *(N)*, type of data *(t)*, source of the breach *(s)*, and whether or not the data has been used for nefarious purposes *(A)*. The BLI is formulated as follows:

$$\mathrm{BLI} = \log_{10}(\mathrm{N} * \mathrm{t} * \mathrm{s} * \mathrm{A})$$

where the type of data *(t)* involved in a breach can be categorized based on its nature and potential impact. It can range from relatively less sensitive data like email addresses or affiliations (=1), to moderately sensitive data like account access credentials (e.g., username/passwords to social media or websites) (=2), and further to highly sensitive data such as financial access credentials (e.g., bank account details or credit card information) (=3). Additionally, it includes identity theft information that can be used to impersonate individuals (=4), and even existential data that holds significant value for national security or poses a threat to business survival (=5). Data breaches *(s)* can occur through various sources, each carrying different levels of risk. These sources include situations where data is compromised due to lost devices such as laptops or USB thumb drives (=1), theft of devices (=2), actions of malicious insiders (=3), attacks by malicious outsiders (=4), and even state-sponsored espionage (=5). Furthermore, the stolen data *(A)* can be utilized to cause harm or theft at different levels. There are scenarios where no immediate action was taken on the stolen data (=1), instances where embarrassing or harmful information was published on platforms like WikiLeaks or hacker blogs (=5), and more severe cases where stolen financial identity data was exploited to fraudulently obtain funds or apply for loans (=10).

After the weighted values for the number of records, data type, source, and whether the data has been used to steal identity or cause harm were determined for each breach event in our database, the BLI score was calculated to measure the severity of the breach. The BLI score was then used to categorize breaches into one of five breach severity levels: minimal (1–2.9), moderate (3–4.9), critical (5–6.9), severe (7–8.9), and catastrophic (9–10). Appendix A includes illustrations of multiple categorized breach examples along with their corresponding BLI score calculations.

Data Analysis

In this section, we present an overview of the mean and standard deviation of the breach level index for various types of data breaches across different industries. Table 1 shows a detailed breakdown of the distribution of the breach level index across different industries. The breach level index is a measure of the severity of the breach, with a higher index indicating a more severe breach. The industries included in the table are BSF, BSO, BSR, EDU, GOV, MED, and NGO. The results

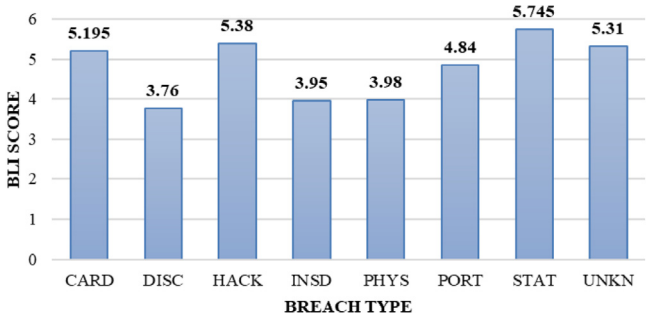

Fig. 2. BLI scores by industry.

Fig. 3. BLI scores by breach type.

show that the mean breach level index across all industries and breach types is 4.43, with a standard deviation (SD) of 2.23. This suggests that the mean breach level index varies across different types of data breaches and industries. The highest mean BLI scores are for HACK (5.63), CARD (5.43), and STAT (5.37) breaches, indicating that these types of breaches are generally more severe in terms of their potential impact across industries. For instance, the mean breach level index for the HACK breach type is highest in the BSR industry (6.49). Similarly, the mean breach level index for the INSD breach type is highest in the BSO industry (5.12). The lowest mean BLI scores are for DISC (3.14), PHYS (3.82), and INSD (4.33) breaches, indicating that these types of breaches are generally less severe in terms of their potential impact across industries.

Fig. 2 illustrates the BLI scores by industry, allowing for a side-by-side comparison of risk levels among different industry sectors. Furthermore, Fig. 3 displays the BLI scores categorized by breach type, enabling a visual analysis of the relative impact of each data breach type.

Our analysis also suggests that the standard deviation of the breach level index varies across different types of data breaches and industries, indicating different levels of severity for security breaches in each category. For example, the mean BLI score for HACK breaches ranges from 3.28 in the NGO industry to 6.49 in the BSR industry. In addition, the BSO industry stands out by having a relatively high mean BLI score

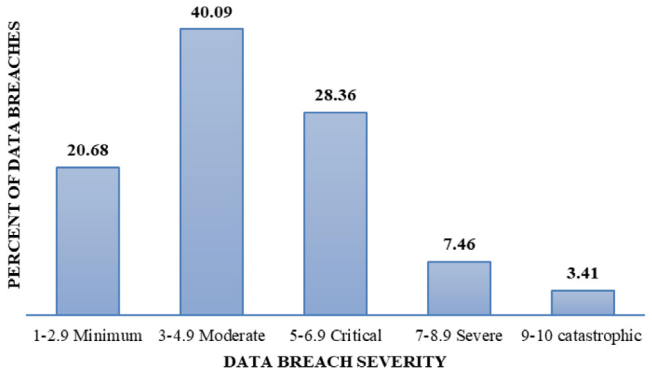

Fig. 4. Number of data breaches based on the severity level.

Table 2
Regression results.

Variable	Regression model
Constant	2.13 (12.60)***
BSF — Business, Financial, and Insurance Sector	0.37 (1.91)*
BSR — Business, Retail/Merchant Sector	0.41 (2.04)**
EDU — Educational Institution Sector	−0.26 (−.67)
MED — Healthcare, Medical Sector	0.05 (0.27)
NGO — Nonprofits Sector	−0.49 (−0.62)
BSO — Business, Other Sectors	0.58 (3.05)***
Breach Type — Unintended disclosure (DISC)	−0.49 (−3.68)***
Breach Type — Hacking or malware (HACK)	0.35 (2.68)***
Breach Type — Payment Card Fraud (CARD)	0.23 (0.79)
Breach Type — Insider (INSD)	−0.26 (−1.71)*
Breach Type — Physical loss (PHYS)	−0.23 (−1.20)
Breach Type — Portable device (PORT)	−0.16 (−1.21)
Breach Type — Stationary device (STAT)	0.33 (0.67)
Breach Type — Unknown (UNKN)	0.12 (0.19)
R^2	0.18
Model F	4.77***

*** $p < 0.01$.
** $p < 0.05$.
* $p < 0.10$.
Dependent variable: Breach Severity
Each cell contains the b-coefficient and the t-statistic in parentheses.
N = 469.

for DISC breaches (4.04) compared to other industries, while the EDU industry stands out by having a relatively low mean BLI score for all breach types. Finally, the UNKN breach type has a limited number of data points and varies widely across industries, indicating a need for further investigation.

Fig. 4 displays a histogram of the percentage of data breaches for each level of severity. It highlights the fact that most data breaches belong to the moderate and critical categories. We performed a linear regression analysis to explore the relationship between the Breach Level Index (BLI) – our measure of breach severity – and the industry sector and breach type, which we treated as independent variables. Our regression model was structured as follows:

$$BLI = \beta_0 + \beta_1 * \text{Industry} + \beta_2 * \text{Breach Type} + \varepsilon$$

Here, BLI represents the dependent variable, capturing the severity of data breaches. The categorical predictor variables, Industry and Breach Type, were used to assess how different sectors and types of breaches contribute to variations in breach severity. The coefficients β_0, β_1, and β_2 were estimated to quantify the impact of each predictor variable, and ε accounted for unobserved factors. The outcomes of our regression analysis are presented comprehensively in Table 2.

The regression model provides some insights into the factors that are associated with the severity of a data breach. Industry sectors BSF and BSO are associated with higher severity of data breaches, while NGO is associated with lower severity. Breach types DISC and INSD are associated with lower severity of data breaches, while breach types HACK and STAT are associated with higher severity. Our regression model explains only 18% of the variance in the severity of data breaches, which suggests that there could be other factors that impact the severity of data breaches that are not captured in this model.

Table 3
Occurrences and severity of breaches by type.

Breach type	Count	Median BLI
CARD	14	5.195
DISC	103	3.760
HACK	126	5.380
INSD	70	3.950
PHYS	35	3.980
PORT	92	4.840
STAT	10	5.745
UNKN	19	5.310
Total	**469**	**4.440**

Table 4
Likelihood and Impact Matrix for Breach Types.

Breach type	Probability	Impact	Risk
CARD	0.029978587	5.195	0.155739
DISC	0.220556745	3.760	0.829293
HACK	0.269807281	5.380	1.451563
INSD	0.149892934	3.950	0.592077
PHYS	0.074946467	3.980	0.298287
PORT	0.197002141	4.840	0.95349
STAT	0.021413276	5.745	0.123019
UNKN	0.03640257	5.310	0.193298

To construct a likelihood and impact matrix, we analyzed the frequency of each breach type and determined the median BLI based on the number of times a breach type occurred within the dataset. Table 3. Occurrences and Severity of Breaches by Type displays the frequency and severity of different breach types, as indicated by the median BLI scores.

Next, we calculated the probability of each breach type by dividing its count by the total number of breaches in the dataset. The impact was determined by taking the median of the BLI scores. The results of the likelihood and impact analysis are presented in Table 4. The results suggest that the breach type with the highest probability is HACK (26.98%), followed by DISC (22.06%) and PORT (19.70%). The breach type with the lowest probability is STAT (2.14%). In terms of impact, the highest impact score is associated with HACK (5.66), followed by CARD (5.43) and STAT (5.37). The breach type with the lowest impact score is DISC (3.14%).

By combining the probability and impact scores, organizations can prioritize their efforts to mitigate the risk of data breaches. To determine the risk score linked to each breach type, we further computed the product of the assessed likelihood and impact. Our results suggest that a breach type with a high probability and high impact (such as HACK) would be considered a high priority for mitigation efforts, while a breach type with a low probability and low impact (such as STAT) may not require significant resources for mitigation.

Based on this result, we performed a quadrant analysis to categorize the different types of data breaches based on their impact and probability. Fig. 5 provides a visual representation of the risk levels associated with different types of data breaches based on their likelihood and impact scores. The quadrant chart categorizes the breaches into four categories, allowing organizations to easily identify which breaches require the most immediate attention.

High Impact/High Probability: This category includes breach types that have a high likelihood of occurring and could have a severe impact on the organization. Since HACK has the highest impact score and is also the most probable breach type, it falls into this category.

Low Impact/High Probability: This category includes breach types that have a high likelihood of occurring but may not have a significant